

README – Kit GQM + PRAGMATIC para indicadores OWASP 2025 – España

Versión 1.0 – Borrador para uso piloto y adaptación institucional

1. ¿Qué es este kit?

Este kit complementa el "Kit de Encuesta OWASP 2025 – España" incorporando explícitamente:

- El enfoque GQM (Goal–Question–Metric) para asegurar que cada indicador se deriva de objetivos claros y preguntas bien formuladas.[web:87][web:95][web:98]
- La meta-métrica PRAGMATIC para evaluar la calidad y utilidad de cada indicador según nueve criterios (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable).[web:88][web:91][web:94][web:96]

El foco son los indicadores M1–M15 definidos a partir de OWASP Top 10:2025, SAMM, ASVS 5.0 y la Metodología de Rating de Riesgo, con vocación de servir como KPIs/KRIs en el contexto ENS/NIS2 en España.[web:2][web:21][web:24][web:60][web:68][web:72][web:97][web:100]

2. Contenido del kit

El kit incluye los siguientes archivos en formato Markdown:

1.
`marco-gqm-pragmatic.md`
Marco conceptual que explica cómo combinar GQM y PRAGMATIC sobre los indicadores OWASP M1–M15.
2.
`matriz-pragmatic.md`
Matriz de evaluación PRAGMATIC completa con puntuaciones (0–5) y comentarios sintéticos para cada indicador.
3.
`narrativa-gqm-pragmatic.md`
Narrativa explicativa para contextualizar el enfoque ante comités, grupos de trabajo o como introducción de documentos.
4.
`mapeo-normativo-gqm.md`
Tabla que mapea cada indicador M1–M15 a objetivos GQM, dominios OWASP y ámbitos NIS2/ENS relevantes.
5.
`plantilla-igm-roi-gqm.md`
Especificación de una plantilla Excel que integra los indicadores M1–M15, las puntuaciones PRAGMATIC, el cálculo de subíndices y del Índice Global de Madurez (IGM) y un módulo de ROI.
6.
`ppt-ejecutivo-gqm.md`
Estructura de una presentación ejecutiva para explicar el marco GQM + PRAGMATIC + OWASP y los resultados asociados.

`marco-gqm-pragmatic.md`

Marco conceptual que explica cómo combinar GQM y PRAGMATIC sobre los indicadores OWASP M1–M15.

`matriz-pragmatic.md`

Matriz de evaluación PRAGMATIC completa con puntuaciones (0–5) y comentarios sintéticos para cada indicador.

`narrativa-gqm-pragmatic.md`

Narrativa explicativa para contextualizar el enfoque ante comités, grupos de trabajo o como introducción de documentos.

mapeo-normativo-gqm.md

Tabla que mapea cada indicador M1–M15 a objetivos GQM, dominios OWASP y ámbitos NIS2/ENS relevantes.

plantilla-igm-roi-gqm.md

Especificación de una plantilla Excel que integra los indicadores M1–M15, las puntuaciones PRAGMATIC, el cálculo de subíndices y del Índice Global de Madurez (IGM) y un módulo de ROI.

ppt-ejecutivo-gqm.md

Estructura de una presentación ejecutiva para explicar el marco GQM + PRAGMATIC + OWASP y los resultados asociados.

3. Cómo encaja con el Kit de Encuesta OWASP

Este kit **no sustituye** al kit de encuesta, sino que lo refuerza:

- El modelo de encuesta sigue siendo la fuente primaria de datos (respuestas de organizaciones sobre prácticas y resultados).
- El presente kit se ocupa de:
- Estructurar las métricas derivadas (M1–M15) con GQM.
- Evaluar la calidad de esas métricas con PRAGMATIC.
- Proporcionar herramientas para su cálculo, interpretación y comunicación.

En la práctica, el flujo recomendado es:

7. Ejecutar la encuesta OWASP y codificar resultados.
8. Traducir respuestas a métricas M1–M15 (normalizadas 0–100).
9. Aplicar el marco GQM + PRAGMATIC para seleccionar y ponderar métricas.
10. Calcular subíndices, IGM y, opcionalmente, ROI.
11. Presentar resultados con la plantilla ejecutiva.

4. Destinatarios del kit

- CISOs y responsables de ciberseguridad que necesiten justificar métricas ante la alta dirección y reguladores.
- Equipos de riesgos y cumplimiento encargados de alinear NIS2/ENS con indicadores técnicos.
- Organismos nacionales (CSIRTs, autoridades competentes NIS2, unidades ENS) que quieran diseñar observatorios y cuadros de mando.
- Investigadores interesados en estudiar métricas de ciberseguridad con un enfoque riguroso.

5. Uso recomendado (modo rápido)

12. Leer marco-gqm-pragmatic.md para entender el enfoque general y los indicadores M1–M15.
13. Revisar matriz-pragmatic.md y decidir qué métricas se utilizarán como "core" en el cuadro de mando.
14. Implementar la hoja Excel siguiendo plantilla-igm-roi-gqm.md.
15. Integrar datos de la encuesta OWASP en la hoja y calcular subíndices/IGM.
16. Preparar un reporte ejecutivo siguiendo ppt-ejecutivo-gqm.md.
17. Utilizar mapeo-normativo-gqm.md para explicar cómo las métricas apoyan el cumplimiento ENS/NIS2.

6. Personalización y evolución

- Puede ajustarse la puntuación PRAGMATIC por métrica en función de la experiencia real en cada sector.
- Se pueden añadir nuevas métricas OWASP (por ejemplo, específicas para entornos OT o para riesgos de IA) siguiendo el mismo patrón GQM + PRAGMATIC.
- Las ponderaciones del IGM y los umbrales de interpretación deben revisarse periódicamente.

7. Limitaciones y advertencias

- El marco PRAGMATIC implica necesariamente cierto grado de juicio experto; las puntuaciones iniciales son una propuesta, no dogma.
- El cálculo del ROI de seguridad es aproximado y depende fuertemente de supuestos sobre riesgo económico.
- Este kit no crea cumplimiento ENS/NIS2 por sí solo, pero ayuda a demostrar de forma cuantitativa el esfuerzo y la eficacia de las medidas implantadas.

8. Próximos pasos sugeridos

18. Validar internamente (o en un grupo de trabajo nacional/sectorial) las metas GQM y las puntuaciones PRAGMATIC iniciales.
19. Ejecutar un piloto en un conjunto reducido de organizaciones para probar el enfoque.
20. Ajustar métricas, ponderaciones y herramientas según las lecciones aprendidas.
21. Escalar a nivel sectorial o nacional si los resultados son útiles para decisiones reales.

Si el kit de encuesta ponía termómetro y tensiómetro, este kit añade el estetoscopio: ayuda a escuchar el corazón de las métricas y a decidir cuáles realmente merecen ser escuchadas con atención.